



CÁTEDRA INCIBE

Digitalización y Ciberseguridad Hídrica

CIBERSEGURIDAD HÍDRICA



Financiado por
la Unión Europea
NextGenerationEU



GOBIERNO
DE ESPAÑA

MINISTERIO
PARA LA TRANSFORMACIÓN DIGITAL
Y DE LA FUNCIÓN PÚBLICA

SECRETARÍA DE ESTADO
DE DIGITALIZACIÓN
E INTELIGENCIA ARTIFICIAL



Plan de
Recuperación,
Transformación
y Resiliencia



INSTITUTO NACIONAL DE CIBERSEGURIDAD

Universitat
de Girona



1. **Introducción:** qué es, términos comunes, definiciones.
2. **Tipos de amenazas:** clasificación utilizada por INCIBE de los tipos de amenazas.
3. **Cómo protegerse:** recomendaciones para protegerse de las amenazas; seguridad de datos, dispositivos y cuentas.
4. **Cómo reportar:** cómo reportar un ciberataque.
5. **Cómo recuperarse:** recomendaciones para recuperarse de un incidente.



¿Qué es la ciberseguridad?

Ciberseguridad es la práctica de asegurar confidencialidad, integridad y disponibilidad de información protegiendo los sistemas digitales y redes de uso o acceso no autorizado.

¿Por qué es importante en el sector del agua?

Los ciberataques podrían impactar en la salud pública, causar interrupciones en el servicio, daños en el equipamiento, pérdida de información confidencial, pérdida de reputación, responsabilidades legales.



Términos comunes

IT

Tecnología de la Información.
Sistemas que gestionan datos y comunicación.

OT

Tecnología Operativa.
Controla y monitoriza equipos industriales, procesos.

Puerto

Punto virtual donde empiezan y terminan las conexiones de red

Firewall

Dispositivo o software que filtra/restringe el tráfico de comunicación de datos entre redes o entre red y internet

Software

Programas y sus datos guardados en el hardware y utilizados por el ordenador

Hardware

Componentes físicos del sistema

Sistema Operativo

Un software que controla la operación de un ordenador i dirige el procesamiento de programas



DIFERENCIA ENTRE IT Y OT

IT (Information Technology): abarca todos los sistemas relacionados con el procesamiento, almacenamiento y transmisión de datos. Esto incluye redes, servidores, bases de datos, y aplicaciones que manejan la información corporativa, como ERP, CRM, correos electrónicos, etc. Objetivo: manejar y proteger información.

OT (Operational Technology): abarca los sistemas y dispositivos que se utilizan para monitorear y controlar procesos físicos en entornos industriales. Esto incluye sistemas SCADA, PLCs (Controladores Lógicos Programables), sensores, actuadores, y otros dispositivos de control. Objetivo: controlar y monitorear procesos físicos.



DIFERENCIA ENTRE IT Y OT – PERSPECTIVA DE CIBERSEGURIDAD

IT: Preocupa la confidencialidad y está orientado a la protección de la información y los sistemas, los sistemas son estándares y modernos, tienen conexión directa a internet, la monitorización se puede llevar a cabo en todas las redes y dispositivos, la respuesta a incidentes se puede hacer tanto via SW como vía HW.

OT: Preocupa la disponibilidad, la continuidad de la operación y la productividad, sistemas antiguos, asilados o conectados a través de la red IT, capacidad de monitorización escasa debido a electrónica de red y protocolos industriales, evaluaciones de seguridad ofensiva solo aceptables en entornos controlados y por personal capacitado.



TAXONOMIA DE LOS CIBERINCIDENTES

1. **Contenido abusivo:** Spam, delito de odio, contenido sexual o violento inadecuado.
2. **Contenido dañino:** sistema infectado, conexión con servidor de mando y control mediante malware, distribución o configuración de malware.
3. **Obtención de información:** escaneo de redes (scanning), análisis de paquetes (sniffing), ingeniería social.
4. **Intento de intrusión:** explotación de vulnerabilidades conocidas, intento de acceso con vulneración de credenciales, ataque empleando exploit desconocido.
5. **Intrusión:** compromiso de cuenta con o sin privilegios, compromiso de aplicaciones, robo.
6. **Disponibilidad:** DoS Denegación de servicio, mala configuración, sabotaje, interrupciones.
7. **Compromiso de la información:** acceso no autorizado a información, modificación no autorizada de información, pérdida de datos.
8. **Fraude:** uso no autorizado de recursos, derechos de autor, suplantación, phishing.



TAXONOMIA DE LOS CIBERINCIDENTES

9. **Vulnerable:** criptografía débil, amplificador DDoS, servicios con acceso potencial no deseado, revelación de información, sistema vulnerable.
10. **Otros:** incidentes que no están reflejados en las categorías anteriores, ataques dirigidos contra organizaciones concretas, sustentados en mecanismos muy sofisticados de ocultación, anonimato y persistencia.

Taxonomía de Referencia para la Clasificación de Incidentes de Seguridad, desarrollada coordinadamente por un grupo internacional de equipos de respuesta a incidentes:

[Reference-Security-Incident-Taxonomy-Task-Force/working_copy/humanv1.md at master · enisaeu/Reference-Security-Incident-Taxonomy-Task-Force · GitHub](https://www.enisa.europa.eu/content/incident-response-taxonomy)



TIPOS DE AMENAZAS

Ataques físicos:

- Contaminación intencional del suministro de agua o de las aguas residuales.
- Sabotaje/manipulación.
- Robo.
- Agresión.
- Vigilancia o interrogatorio sospechoso.
- Amenazas.



CÁTEDRA INCIBE

Digitalización y Ciberseguridad Hídrica

CÓMO PROTEGERSE

SEGURIDAD DE CUENTAS

**SEGURIDAD DE
DISPOSITIVOS**

SEGURIDAD DE DATOS



SEGURIDAD DE CUENTAS

Utilizar contraseñas seguras: cambiar siempre las contraseñas por defecto y utilizar contraseñas seguras para todos los sistemas IT y OT.
-Contraseñas largas, aleatorias, únicas, con números y símbolos. Usar un gestor de contraseñas para recordarlas.

Requerir credenciales diferentes para usuarios de IT y OT



Username: ITUser2
Password: Pa\$\$w0rD



Username: OTUser2
Password: Il0v3w@t3r



SEGURIDAD DE CUENTAS

Establecer autenticación de múltiple factor: requerir confirmación de identidad mediante un Pin, un smartphone, huella dactilar,...

Gestionar privilegios de usuario y acceso: separar privilegios de cuentas de administrador y de usuarios normales, eliminar accesos que no son necesarios para el usuario,...

Bloquear el login en casos que haya muchos intentos de login erróneos.



SEGURIDAD DE DISPOSITIVOS

Mantener un inventario preciso de los activos de IT y OT, es la base saber lo que se tiene para poder protegerlo y asegurarlo.

Qué	Por qué	Quién	Cómo
-Qué tiene que ser protegido -Que niveles de protección están disponibles -Qué Interconexiones y dependencias son necesarias	- Es un sistema crítico - És un sistema valioso	Tiene la responsabilidad del activo	-Son los escenarios worst-case si se compromete el activo -Métodos para el usuario para acceder al activo -Fluye la información a través del sistema



SEGURIDAD DE DISPOSITIVOS

Mantener el software actualizado: Los sistemas operativos, navegadores web, programas y aplicaciones son susceptibles de tener fallos de seguridad. Por este motivo, pueden necesitar ser actualizados, independientemente del dispositivo en el que se encuentren instalados.

Eliminar conexiones innecesarias como no conectar USB externos, ordenadores o teléfonos móviles o apagar conexiones entre dispositivos que no sean necesarias como bluetooth y otras.



SEGURIDAD DE DATOS

Recopilar registros de seguridad: ayudan a lograr una mejor visibilidad para detectar y responder de manera eficaz a un incidente cibernético. Recopile y almacene registros sobre el tráfico de red relacionado con incidentes de seguridad y actividades sospechosas.

Usa encriptación efectiva: Habilite Secure Socket Layer/Transport Layer Security (SSL/TLS) para proteger los datos en tránsito. Muchos navegadores web tienen esta opción habilitada de manera predeterminada.



SEGURIDAD DE DATOS

Cifrado de datos: Puede ayudar a mantener la confidencialidad de los datos y la integridad de las redes de IT y OT. No almacene ningún dato confidencial en formato de texto plano. Permita el acceso a los datos confidenciales únicamente a usuarios autorizados.



¿Cómo reportar un ciberincidente?

La normativa NIS2, pendiente de transposición en España indicará a quién reportar, qué reportar y cómo. Por el momento se puede consultar la guía y el organismo competente [Guía nacional de notificación y gestión de ciberincidentes | INCIBE-CERT | INCIBE](#)

Tipo de operador	Características	Organismo competente
Operador de servicios esenciales	Sector Público (entidades incluidas en el ámbito subjetivo de aplicación de la Ley 40/2015)	CCN-CERT
	Sector Privado (entidades no incluidas en el ámbito subjetivo de aplicación de la Ley 40/2015)	INCIBE-CERT



Crear un plan de respuesta a incidentes: Documento con procedimientos detallados sobre como responder a un ciberataque puede minimizar los tiempos de respuesta y recuperación.

Tener un backup de los sistemas necesarios para las operaciones: hacer y guardar una copia de todos los sistemas necesarios para la operación y comprobar que la copia funciona. Guardar los backups separadamente del origen.

Tener la documentación de redes actualizada